



中华人民共和国国家标准

GB/T 36318—2018

电子商务平台数据开放 总体要求

Data openness for E-commerce platform—General requirement

2018-06-07 发布

2018-10-01 实施

国家市场监督管理总局 发布
中国国家标准化管理委员会

目 次

前言 III

1 范围 1

2 术语和定义 1

3 电子商务数据开放模型 2

 3.1 模型框架 2

 3.2 角色与职责 3

 3.3 模块与接口 3

4 数据开放总则 4

 4.1 数据分级 4

 4.2 数据安全 5

 4.3 数据生命周期管理 5

5 电子商务平台服务商的要求 5

 5.1 技术要求 5

 5.2 管理要求 7

6 第三方软件提供商的要求 7

 6.1 技术要求 7

 6.2 管理要求 8

参考文献..... 9



前 言

本标准按照 GB/T 1.1—2009 给出的规则起草。

本标准由全国电子业务标准化技术委员会(SAC/TC 83)提出并归口。

本标准起草单位:阿里巴巴(中国)有限公司、中国标准化研究院、国家应用软件产品质量监督检验中心、任我行网络技术有限公司、上海百胜软件股份有限公司、北京淘宝科技有限公司、友盟同欣(北京)科技有限公司、泉州市晋科技术检测有限公司、福州市标研信息技术有限公司、安徽艺标信息科技有限公司、四川红世财智网络科技有限公司、东莞快创信息科技有限公司、广东潮族实业有限公司、成都口口鲜猫信息技术有限公司。

本标准主要起草人:朱红儒、李克鹏、陈艳军、王志民、隋媛、咸奎桐、李奕飞、叶琳、韩桃玲、张世长、孙旭东、杨军、贾科、郭澍、宋红波、张啸、程东、崔从俊、安伟、董丽、罗显发、柴治、郑伟山、黄平。



电子商务平台数据开放 总体要求

1 范围

本标准规定了电子商务平台服务商与第三方软件提供商之间数据开放的术语和定义、模型和总则，以及对电子商务平台服务商和第三方软件提供商在数据开放过程中的技术要求和管理要求。

本标准适用于电子商务活动中的电子商务平台服务商和第三方软件提供商进行数据开放相关系统的研发、部署、运行、维护和管理。

2 术语和定义

下列术语和定义适用于本文件。

2.1

电子商务 electronic commerce

以电子形式进行的商务活动。

注：经济活动主体之间利用现代信息技术和网络技术(含互联网、移动网络和其他信息网络)开展商务活动，实现网上接洽、签约、支付等关键商务活动环节的部分或全部电子化，包括货物交易、服务交易和知识产权交易等。

[GB/T 31524—2015, 定义 3.1]

2.2

用户 user

使用电子商务交易平台的机构或自然人，以注册的标识与用户信息为判断依据。

2.3

商家 merchant

在电子商务平台上发布产品与服务销售信息的组织。

2.4

加密 encipherment/encryption

对数据进行密码变换以产生密文的过程。一般包含一个变换集合，该变换使用一套算法和一套输入参量。输入参量通常被称为密钥。

[GB/T 25069—2010, 定义 2.2.2.60]

2.5

电子商务平台服务商 electronic commerce platform service provider

为电子商务活动提供平台服务的组织或机构。

2.6

第三方软件 the third party software

由第三方开发或提供的用于辅助电子商务业务开展的软件。

2.7

安全事件 security event

由单个或一系列意外或有害的安全事态所组成的，极有可能危害业务运行和威胁信息安全。

注：安全事件特指电子商务安全事件，不仅包括网络上出现的攻击造成的安全事件，也包括电子商务业务应用中出现的欺诈、盗号、违禁等恶意行为。

2.8

订单 order

消费者向单一商户同一时间拍下单款或多款商品或服务的合约。

2.9

回滚 rollback

程序或数据处理错误,将程序或数据恢复到上一次正确状态的行为。

注：回滚包括程序回滚和数据回滚等类型。

2.10

业务 business

电子商务活动中所需处理的各种事务。

2.11

用户数据 user data

由用户产生的基本信息和用户提供给电子商务平台或第三方软件使用的数据。

2.12

业务数据 business data

业务开展所需要的数据,包括但不限于用户的行为数据、根据用户数据和用户行为数据加工获得的数据。

2.13

脱敏 desensitization

通过模糊化等方法处理原始数据,以实现屏蔽敏感数据且屏蔽后的数据不可逆向恢复的数据保护方式。

3 电子商务数据开放模型

3.1 模型框架

电子商务数据开放涉及电子商务平台服务商及第三方软件提供商,涵盖业务单元、数据开放平台、第三方软件以及数据供应和数据共享两类接口。电子商务的数据开放模型见图 1 所示。

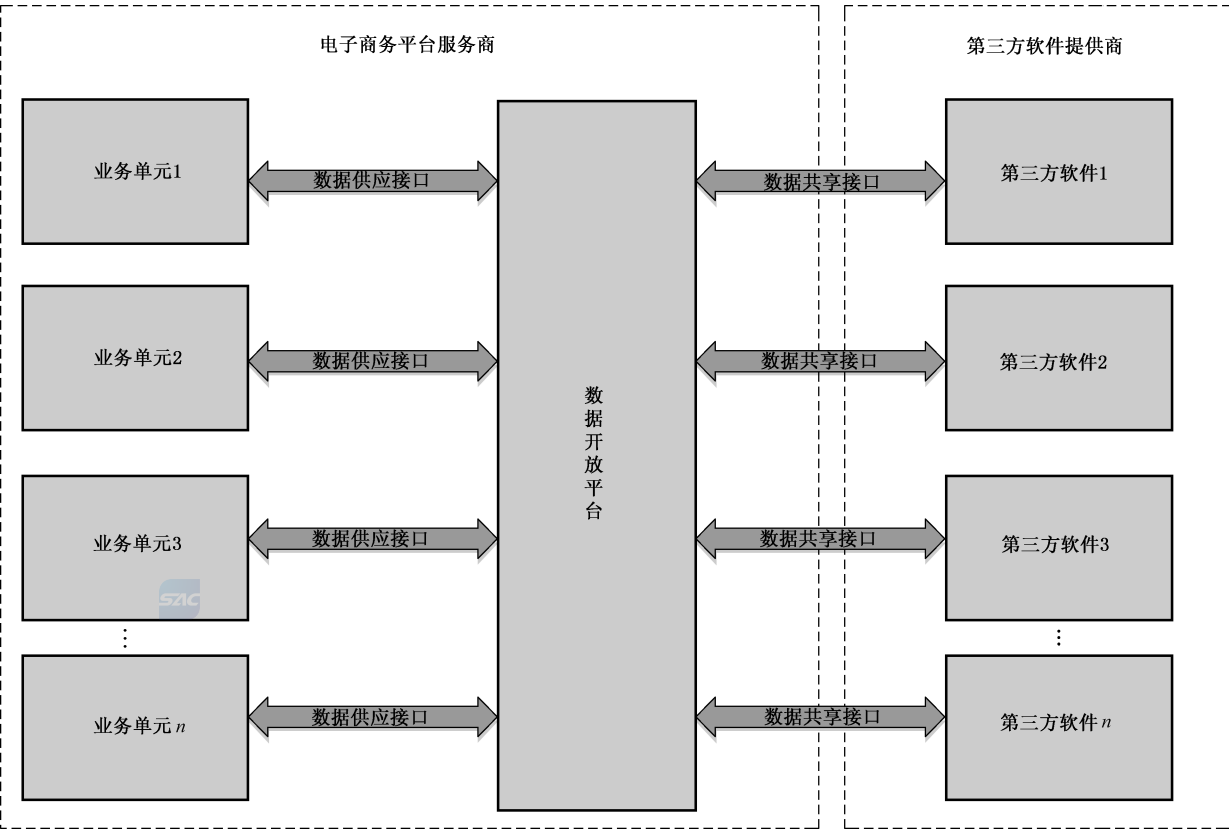


图 1 电子商务数据开放模型

3.2 角色与职责

3.2.1 电子商务平台服务商

电子商务平台服务商负责搭建与运营电子商务业务单元及电子商务数据开放平台,实施对电子商务业务数据的生命周期管理,保证数据的真实、完整及可追溯。

电子商务平台服务商的职责应包括但不限于:

- a) 确认第三方软件提供商的企业资质,管理接入的第三方软件提供商;
- b) 根据 4.1 的原则,划分数据的等级,并基于数据等级实施相应的保护;
- c) 确定数据开放的策略和范围,管理数据开放的权限,控制数据访问的风险;
- d) 跟踪数据流向,确保数据访问的可追溯。

3.2.2 第三方软件提供商

第三方软件提供商研发和运营第三方软件,负责管理从数据开放平台获取的授权数据,并防止数据泄露。第三方软件提供商的职责应包括但不限于:

- a) 应向电子商务平台服务商提交应用审核申请,申请内容包括公司资质、应用功能、希望访问的数据级别等,便于平台服务商确定应用的合法性和相应的权限;
- b) 从数据开放平台访问用户数据前需明确获得用户的授权;
- c) 应通过运营和技术手段防止用户数据泄露。

3.3 模块与接口

3.3.1 业务单元

业务单元是用户在电子商务平台上进行特定电子商务活动的系统单元,记录并存储与电子商务活动相关的数据,并为数据定义开放的策略。

示例: 航旅业务单元、视频业务单元、商品零售业务单元。

3.3.2 数据开放平台

数据开放平台是由电子商务平台服务商建设并运营的平台系统,是第三方软件访问业务单元的入口,并集中管理数据的访问权限。

其与业务单元间通过数据供应接口通信,向第三方软件开放数据。

3.3.3 第三方软件

第三方软件是由第三方软件提供商独立开发或提供的软件,向用户提供电子商务的辅助服务,以增强消费者的购物体验,或者协助商家进行订单管理、营销推广和数据分析等事务。

3.3.4 数据供应接口

数据供应接口是业务单元与数据开放平台之间的通信接口,用于电子商务活动相关数据在平台与业务单元之间的双向交互。

3.3.5 数据共享接口

数据开放平台通过数据共享接口对第三方软件提供经用户授权的电子商务活动数据;第三方软件通过数据共享接口向数据开放平台传递其产生的数据。

4 数据开放总则

4.1 数据分级

4.1.1 数据等级及开放策略

业务单元应根据数据的敏感程度、数据保密性要求、数据访问授权的对象不同,对数据进行等级划分,实施不同的开放共享策略。数据可划分为 4 个等级,见表 1。

表 1 数据分级

项目	级别			
	一级	二级	三级	四级
特点	开放无影响 或影响极小	大范围开放 有负面影响	含有部分敏感 数据,开放会 产生负面影响	数据高度敏感, 泄露会产生 严重影响
开放策略	默认开放	授权开放	脱敏开放	禁止开放

4.1.2 一级数据

一级数据指公开会对用户或业务没有影响或影响极小的非敏感数据,包括:

- a) 用户可公开数据:用户自行公开发布的合法数据,该数据的自由传播是促进相关电子商务活动开展的必要条件;

示例:商品说明、店铺基本信息、客服联系方式等。

- b) 业务可公开数据:电子商务平台服务商或业务单元自行公开发布的数据,允许数据自由传播而不会产生任何安全或法律问题。

示例:商家的等级、活动招商规则、前台类目数据。

4.1.3 二级数据

二级数据指大范围开放会产生潜在不良影响,但因用户或业务的要求需要对指定群体开放的数据。二级数据需经数据所有者授权在特定范围内开放,主要包括:

- a) 用户可共享数据:用户已授权可对指定人群公开的数据;

示例:用户相册。

- b) 业务内部数据:仅限组织内部人员访问的与电子商务业务运营相关的数据,如果泄露,可能会对局部业务产生负面影响,或对商家和用户造成较低程度的损失或影响。

示例:交易成交总额。

4.1.4 三级数据

三级数据指包含用户隐私或业务敏感信息,直接开放会对用户或业务产生负面影响的数据。三级数据开放前需要脱敏处理,避免泄露用户隐私或业务秘密。包括:

- a) 用户隐私数据:任何只对用户本人可用的或者关于用户本人的信息,该类信息属于用户未在网站上直接公开的自然、资质和行为信息。该类信息的泄露会给用户带来骚扰,影响用户的正常生活、工作等,一般可细分为以下两类:

- 1) 个体属性隐私数据:可定位到个体身份的数据;

示例：地址、电话、电子邮箱等。

2) 个体行为隐私数据：可以追溯并锁定个人与电子商务业务关联产生的行为隐私数据。

示例：购买纪录、收货人详细信息和聊天记录等。

- b) 业务保密数据：仅限组织内部特定人群访问，如果非授权的泄露将直接或间接对电子商务平台用户或者员工造成不利影响。造成经济损失、商业损失，破坏电子商务平台的声誉，并可能发生潜在的法律风险。

示例：类目的各种交易明细/排名，类目产品的业务数据，后台类目、物流数据、类目财务数据。

4.1.5 四级数据

四级数据指用户或业务高度敏感的数据，一旦泄露可能对用户及服务商权益造成严重不利影响。应禁止开放四级数据，包括：

- a) 用户高敏感数据：用户进行商务交易的身份凭证及认证凭据类数据，包括用户密码，银行账号，密码提示问题及答案等；
- b) 业务高敏感数据：非授权的泄露会对电子商务平台服务商或第三方软件提供商造成严重影响的数据。

4.2 数据安全

电子商务平台服务商在对第三方软件提供商开放数据的过程中，应符合相关法律法规的规定。应采取措施保证数据的有序开放，控制所开放的数据被泄露或篡改的风险，并可对第三方软件提供商使用的相关数据进行跟踪和审计。

第三方软件提供商应明确从电子商务平台服务商获取数据的目的和范围，在此目的范围内使用，并采取措施避免所开放的数据被泄露或篡改。

4.3 数据生命周期管理

电子商务平台服务商和第三方软件提供商应对数据全生命周期管理和监控，涵盖数据产生、数据存储、数据使用、数据共享和数据销毁等各个环节，以保证数据的真实、完整和可追溯。

5 电子商务平台服务商的要求

5.1 技术要求

5.1.1 数据产生

5.1.1.1 授权许可

业务单元在记录用户录入的数据时应获得用户明确的授权许可。

电子商务平台服务商应基于用户的授权凭证决定是否对第三方软件提供商提供相关的用户数据。

5.1.1.2 数据分级

业务单元在处理电子商务活动，记录并生成相关数据时，应基于数据分级开放准则为所有数据标识级别。

电子商务数据开放平台应遵循 5.1.1 的要求，仅向第三方软件开放一级、二级和三级的数据。

5.1.2 数据存储

5.1.2.1 数据加密

对于三级及四级数据,业务单元或数据开放平台宜支持加密存储。

5.1.2.2 备份与恢复

业务单元或数据开放平台应对存储其上数据进行备份。备份方式包括本地备份和异地备份,数据开放平台应至少支持其中一种备份方式。

业务单元或数据开放平台应支持增量数据备份和数据恢复的功能。

5.1.3 数据使用

5.1.3.1 访问控制

第三方软件通过数据开放平台获取用户数据时,应向平台提供用户的授权凭证。

数据开放平台在返回数据给第三方软件前,应验证数据调用方的身份,并确保该软件具备对应的数据权限,并获得了用户授权。

数据开放平台应保证不同用户之间的数据相互隔离。

5.1.3.2 回滚

数据开放平台中执行的数据操作应支持操作回滚。

5.1.4 数据共享

5.1.4.1 数据接口权限

数据共享接口应能基于数据的等级对第三方软件的访问执行访问控制。

5.1.4.2 数据脱敏

数据开放平台在向第三方软件传输三级数据时,应对数据进行脱敏处理。

5.1.4.3 数据传输安全

数据开放平台应具备数据传输安全保护能力,保证数据的完整性、机密性、可用性及不可抵赖性。

5.1.4.4 权限管理

数据开放平台需要具备如下能力:

- a) 数据开放平台应有能力定期验证用户身份;
- b) 数据开放平台应有能力撤销用户对第三方软件的授权;
- c) 数据开放平台应有能力封闭第三方软件的账号。

5.1.4.5 数据流向追踪

数据开放平台应具备数据流向查询和流向异常预警的能力。

5.1.5 数据销毁

执行数据计算和存储的设备在弃置、转售或捐赠前应将其上所有数据彻底删除,并无法恢复。

5.2 管理要求

5.2.1 系统部署

电子商务平台服务商负责研发和部署数据开放相关的应用和支撑系统时,应保障系统生命周期的安全,实施安全需求分析、安全设计、代码安全审计、安全测试及发布安全审核等活动。

5.2.2 服务运维

电子商务平台服务商运营数据开放服务时,应涵盖以下活动:

- a) 漏洞管理:电子商务平台服务商应建立漏洞管理机制,监控系统漏洞及风险,如定期的系统安全扫描;若发现漏洞,应及时处理并修复;
- b) 应急响应:电子商务平台服务商应设立应急响应的组织,建立相应的流程和机制,制定应急响应计划,处理安全事件,如数据泄露事件;
- c) 事件追查:对于所发生的针对数据开放平台的安全事件,应建立机制保证攻击可溯源。

6 第三方软件提供商的要求

6.1 技术要求

6.1.1 数据产生

第三方软件需通过数据开放平台的用户授权机制,获取访问用户数据的授权;所获取的用户数据只能返回给授权用户。

第三方软件应保证不同用户的数据的隔离,防止非授权访问。

6.1.2 数据存储

第三方软件从数据开放平台获取并保存的三级数据宜支持加密存储。

6.1.3 数据使用

不同安全等级的数据,在第三方软件中的使用应在不同等级的运行环境(如表 2 所示)中进行。

表 2 运行环境要求

数据等级	运行环境要求
一级数据	一般环境
只读的二级数据及三级数据	可监视环境
可写的二级数据及三级数据	可控环境

可监视环境要求:

- 用户对应用数据的所有操作应写入日志,以支持审计和监控;
- 相关软件需通过严格的安全测试,并定期扫描。

可控环境要求:

- 包含所有可监视环境要求;
- 该环境需运行于隔离的网络下,只能通过限定的流通和管理通道与公众网络交互。

6.1.4 数据共享

6.1.4.1 数据返回

第三方软件与数据开放平台间应建立双向通道,第三方软件一方面从数据开放平台获取授权数据,另一方面第三方软件在数据状态发生改变后将更新的数据通过数据共享接口返回给数据开放平台。以订单处理为例,第三方订单管理软件从数据开放平台获取商户的订单数据,当订单状态变更时,其应向数据开放平台返回更新的订单状态数据。

6.1.4.2 第三方软件间的数据共享

第三方软件之间应通过数据开放平台的数据交换服务实现第三方软件间的数据共享。

6.1.4.3 数据流向追踪

第三方软件应记录访问数据的用户端来源、用户信息、时间、数据等信息。

如果第三方软件自动传递数据到其他系统,应记录数据传递的目的地、时间、数据等信息。

第三方软件应返回数据流向信息给数据开放平台。

6.1.5 数据销毁

计算机或设备在弃置、转售或捐赠前应将其所有数据彻底删除,并无法复原,以免造成信息泄露。

6.2 管理要求

6.2.1 系统部署

第三方软件提供商应保障软件的生命周期安全,开展安全需求分析、安全设计、代码安全审计、安全测试及发布安全审核等活动。

6.2.2 服务运维

第三方软件提供商在通过第三方软件向商户提供服务时,应具备如下功能:

- a) 漏洞管理:应建立漏洞管理机制,监控第三方软件及系统的漏洞和风险,如定期的系统安全扫描;若发现漏洞,应及时处理并修复;
- b) 应急响应:第三方软件提供商应设立应急响应组织,建立相应的流程和机制,应对可能发生的安全事件,如数据泄露事件,避免安全影响的进一步扩散;
- c) 事件追查:对于已爆发的针对应用的安全事件,应建立机制保证对攻击溯源。

6.2.3 对外包的管理

第三方软件提供商若采用分包商对数据进行处理,应明确告知电子商务平台服务商,并对其外包商进行管理和审计,保证数据在外包商的使用符合本章的要求。

参 考 文 献

- [1] GB/T 25069—2010 信息安全技术 术语
 - [2] GB/T 31524—2015 电子商务平台运营与技术规范
 - [3] GB/T 35408—2017 电子商务质量管理 术语
-

